



SECURE SOFTWARE ENGINEERING MECR2323
SECTION 01

LECTURER

TS DR. MOHD ZAMRI BIN OSMAN

ASSIGNMENT 1

PROTECTION PROFILES AND SECURITY TARGETS IN WEB APPLICATION

Web Application Category: Online Banking Web Application

Specific System Name: SentinelWeb Digital Banking Portal v2.0

NAME	MATRIC NO.
KEERTENNAH DEVI A/P PONNAMBALAM	MEC254026

PART A: Protection Profile (PP) – Role: Security Customer [30 marks]

Chosen application category: Online banking web application

Customer will have access to their bank accounts through a banking app on the Internet and be able to manage all their accounts through the app. Customer will be able to check their account balance, transfer funds between accounts, and pay bills. Customers will also be able to view or download their account information. This application can be used by retail banking clients, customer service representatives, and banking administrators. The security of this app is extremely important because of all the personal and financial information contained in it. Therefore, the organization will need to implement sufficient security controls to protect the data in the app such as confidentiality, integrity, availability, accountability, and customer privacy.

A1. Security Objectives [8 marks]

The following security objectives define the high-level security goals that online banking web application must achieve to be considered secure.

Security Objective ID	Security Objective	Security Principle
O.CONF	The system shall ensure that customer financial information, personal data, account balances, and transaction details are accessible only to authorized users and protected against unauthorized disclosure.	Confidentiality
O. INTEG	The system shall preserve the accuracy, completeness, and consistency of banking data and financial transactions by preventing illegal alteration or manipulation.	Integrity
O. AVAIL	The system should ensure that authorized users have dependable and ongoing access to financial services while also resisting service outages and cyberattacks.	Availability
O. AUTH	The system must validate all users' identities and implement strong authentication measures for critical processes before allowing access to banking services.	Authentication
O. AUDIT	The system shall record and keep security-related activities for accountability, monitoring, incident investigation, and regulatory compliance.	Accountability
O. PRIV	The system should safeguard customer personal information throughout its lifecycle by incorporating privacy-by-design principles and adhering to applicable data protection standards.	Privacy by Design
O. NONREP	The system shall give evidence of completed financial transactions so that users cannot falsely deny carrying out allowed operations.	Non-Repudiation
O.SESSMGMT	The system shall enforce secure session management by issuing unique cryptographic session tokens, enforcing session expiry after inactivity, and instantly invalidating sessions upon logout or detection of an anomaly.	Session Security

A2. Functional Security Requirements [8 marks]

The following Functional Security Requirements (FSRs) define the security functions that an online banking web application must implement to achieve the security objectives established in A1.

A2.1 Functional security requirements descriptions and traceability

Requirement ID	Requirement Name	Description	Traceability
FIA_UID.1	User Identification	The system shall uniquely identify every customer, administrator, and support staff member using a unique account identifier before allowing access to any protected resources.	O.AUTH
FIA_UAU.1	Multi-Factor Authentication	The system shall authenticate with at least two independent authentication factors, such as passwords and one-time verification codes, before accessing online banking services or conducting high-value transactions.	O.AUTH
FIA_AFL.1	Login Failure Handling	The system shall temporarily lock user accounts after five consecutive failed authentication attempts and record the event in the audit log.	O.AUTH
FDP_ACC.1	Access Control Enforcement	The system shall enforce role-based access control policies to ensure that users can only access the resources and functions necessary for their given responsibilities.	O.CONF, O.AUTH
FDP_ENC.1	Sensitive Data Encryption	The system shall encrypt customer information, credentials, transaction records, and session data both during transmission and when retained in databases and backups.	O.CONF, O.PRIV
FCS_COP.1	Cryptographic Operations	The system employs certified cryptographic methods and key lengths to protect sensitive data and ensure secure communications.	O.CONF, O.INTEG
FPT_INT.1	Transaction Integrity Protection	The system shall verify that transaction requests have not been updated before execution and reject any transaction that fails integrity validation.	O.INTEG
FAU_GEN.1	Audit Log Generation	The system shall automatically log security-related events such as successful and failed login attempts, fund transfers, privilege changes, administration operations, and security configuration changes.	O.AUDIT

FAU_STG.1	Audit Log Protection	The system shall secure audit logs from unauthorized access, modification, deletion, or manipulation.	O.AUDIT, O.INTEG
FMT_MOF.1	Security Management	The system shall restrict security configuration modifications, account management activities, and privilege assignment to approved administrative personnel.	O.AUTH, O.AUDIT
FPT_REC.1	Secure Recovery	The system shall maintain secure backup and recovery processes to ensure that vital services and customer data are restored in the event of a system failure or cyber incident.	O.AVAIL
FCO_NRO.1	Non-Repudiation Services	The system should keep reliable records of completed financial transactions, including timestamps and user identities, to aid in dispute settlement and accountability.	O.NONREP
FIA_SOS.1	Session Token Management	For each authenticated session, the system generates cryptographically random, unique session tokens, which are promptly invalidated upon logout, session timeout, or detection of suspicious activity.	O.AUTH, O.SESSMGMT
FDP_IFC.1	Input Validation and Filtering	The system shall validate and sanitize all user-supplied inputs on both the client and server sides to prevent injection-based attacks such as SQL injection, Cross-Site Scripting (XSS), and Cross-Site Request Forgery (CSRF).	O.INTEG, O.CONF

A3. Non-Functional Security Requirements [7 marks]

Non-Functional Security Requirements (NFSRs) describe the security-related quality traits and operational characteristics that an online banking web application must meet. Unlike functional requirements, these requirements are concerned with the security of the system's operations. Each requirement has a measurable goal criterion and a security justification.

Requirement ID	Requirement	Measurable Target Criterion	Security Rationale
NFSR-01	Session Timeout	User sessions will automatically expire after 15 minutes of inactivity.	Reduces the risk of unauthorized access caused by unattended or abandoned sessions.
NFSR-02	Service Availability	The system shall maintain a minimum yearly up time of 99.95% excluding scheduled maintenance.	Provides uninterrupted access to financial services while minimizing business disturbance.
NFSR-03	Disaster Recovery	The system shall achieve a Recovery Time Objective (RTO)	Ensures that services are restored quickly and data loss

		of less than 2 hours and a Recovery Point Objective (RPO) of less than 15 minutes.	is minimized in the event of a system breakdown or cyber incident.
NFSR-04	Secure Failure Behaviour	The system shall fail closed whenever security mechanisms encounter errors or become unavailable.	Prevents unauthorized access during abnormal operating conditions.
NFSR-05	Vulnerability Remediation	Critical security vulnerabilities must be addressed within 72 hours after discovery, while high-risk vulnerabilities must be resolved within 7 days.	Reduces exposure to identified risks and restricts exploitation chances.
NFSR-06	Security Event Logging Performance	Security logs must be created and saved within 5 seconds of a security-related event occurring.	Ensure prompt monitoring, incident detection, and forensic investigations.
NFSR-07	Encryption Performance	Encryption and decryption processes may not increase typical transaction response times by more than 10%.	Ensures that security controls do not have a substantial impact on user experience or system functionality.
NFSR-08	TLS Protocol Enforcement	The system must enforce at least TLS 1.2, with TLS 1.3 preferable, and must reject any connections made using deprecated protocols (SSLv3, TLS 1.0, TLS 1.1).	Prevents man-in-the-middle attacks and ensures that all data in transit is encrypted using modern, non-vulnerable protocols.

A4. Regulatory Considerations [7 marks]

Online banking systems operate in a highly regulated environment due to the handling of sensitive personal information, financial transactions, payment card data, and critical banking services. As a result, the Protection Profile needs to comply with both internationally accepted security standards and pertinent Malaysian requirements.

Framework	Issuing Body	Scope	Application for Online Banking Security Requirements
Personal Data Protection Act (PDPA) 2010	Parliament of Malaysia	Protection of personal data processed in commercial transactions	Enforces O.PRIV and O.CONF by mandating the secure encryption of customer data and ensuring privacy-by-design principles are applied to all personal information handling. It also supports O.AUTH by requiring strict access controls to prevent unauthorized data exposure.
Risk Management in	Bank Negara Malaysia (BNM)	Technology risk governance and cybersecurity	Directly addresses O.AVAIL by mandating robust incident response, continuous monitoring and strict

Technology (RMiT)		requirements for financial institutions	disaster recovery parameters for financial institutions. It enforces O.AUTH and O.AUDIT by requiring stringent technology risk governance, multi-factor authentication, and comprehensive security event logging.
PCI DSS v4.0	PCI Security Standards Council	Security requirements for payment card data processing and storage	O.CONF and O.INTEG by requiring robust encryption and integrity checks for any payment. Furthermore, it explicitly supports O.AUDIT through continuous security monitoring and immutable audit trails, while enforcing O.AUTH by strictly restricting access to financial data.
ISO/IEC 27001:2022	International Organization for Standardization (ISO) and International Electrotechnical Commission (IEC)	Information Security Management System (ISMS) requirements	Provides the overarching Information Security Management System (ISMS) framework that guarantees O.AVAIL through rigorous business continuity planning. It also underpins O.CONF, O.INTEG, and O.AUDIT by mandating a systematic, risk-based approach to managing sensitive banking information and tracking security incidents.
OWASP ASVS v4.0	OWASP Foundation	Application security verification requirements for web applications	Crucial for defending against modern web vulnerabilities, this framework directly fulfills O.SESSMGMT and O.AUTH through stringent session token and authentication verification. By aligning these verification standards with broader threat models like the OWASP Top Ten risks it ensures O.INTEG is maintained through rigorous input validation to prevent injection flaws.

Part B: Security Target (ST) – Role: Solution Provider [30 Marks]

B1: TOE Description and Implemented Security Features [10 marks]

Target of Evaluation (TOE) Description

- System Name and Version: SentinelWeb Digital Banking Portal v2.0
- Developer Context: Sentinel Financial Group (a fictitious regional retail bank).
- Brief Functional Description: An all-inclusive web-based financial platform that allows consumers to pay their bills, move money between banks, monitor their accounts in real

time, and manage their accounts securely. With proactive defenses against specialized vulnerabilities like encryption oracles and alignment with the most recent OWASP Top Ten security threats, the application has been specifically hardened against contemporary attack vectors.

- **Deployment Environment:** Containerized microservices architecture is used to host on Amazon Web Services (AWS). Strict network segregation between public-facing web layers, backend application logic, and database environments is ensured by deployment within a highly limited Virtual Private Cloud (VPC) in the ap-southeast-1 region. Using a reputable, licensed Certificate Authority (CA) for stringent TLS 1.3 enforcement, web access is limited to HTTPS only. Environments for development, staging, and production are physically and conceptually separate.
- **TOE Boundary:**
 - Included within the evaluation scope: The React.js web frontend, all Spring Boot backend REST APIs, the centralized Auth0 identity management service, the internal cryptographic operations module, the PostgreSQL customer and transaction database, and the ELK-based audit logging services.
 - Explicitly excluded from the evaluation scope: Customer end-user devices, underlying AWS physical infrastructure and hypervisors, external third-party payment clearinghouses, and external Internet service provider (ISP) routing infrastructure are specifically excluded from the assessment scope.

PP-to-ST Traceability Table

PP Requirement	Implemented Feature	Technology / Configuration	Objective Met
FIA_UID.1	Centralized Identity Management	Auth0 Universal Login with unique sub claim per user assigned at registration	O.AUTH
FIA_UAU.1	Multi-factor authentication	Auth0 MFA with TOTP	O.AUTH
FIA_AFL.1	Account Lockout Mechanism	Mechanism Auth0 Brute-Force Protection for example the account locked after 5 consecutive failures and unlock via verified email	O.AUTH
FDP_ACC.1	Role-Based Access Control	Spring Security PreAuthorize annotation. Roles: CUSTOMER, SUPPORT, ADMIN for each restricted to minimum necessary endpoints	O.CONF, O.AUTH
FDP_ENC.1	Data encryption	AES-256 at rest and TLS 1.3 in transit	O.CONF, O.PRIV

FCS_COP.1	Cryptographic Operations	BouncyCastle FIPS Provider integrated into Spring Boot, RSA-2048 for key exchange and AES-256 for symmetric encryption	O.CONF, O.INTEG
FPT_INT.1	Transaction Integrity Validation	HMAC-SHA256 Payload signing applied to all fund transfer API request and any tampered payload is rejected before processing	O.INTEG
FAU_GEN.1	Security audit logging	ELK Stack centralized logging all security events timestamped and centrally stored	O.AUDIT
FAU_STG.1	Log Immutability	AWS S3 Object Lock (Compliance Mode). For example, logs cannot be deleted or modified even by administrators	O.AUDIT, O.INTEG
FMT_MOF.1	Administrative Interface	Dedicated Admin Portal with step-up MFA and admin actions logged separately	O.AUTH, O.AUDIT
FPT_REC.1	Disaster recovery	Automated backups and failover across AWS Multi-AZ	O.AVAIL
FCO_NRO.1	Cryptographically Signed Digital Receipts	PostgreSQL immutable ledger tables with UTC timestamping and HMAC-SHA256 signatures per transaction	O.NONREP
FIA_SOS.1	Secure Session Token Management	Auth0 issues signed JWT tokens (RS256). When tokens expire after 15 minutes of inactivity, the logout calls Auth0 /v2/logout to invalidate all active tokens immediately	O.AUTH, O.SESSMGMT
FDP_IFC.1	Input Validation and Sanitization	Server-side validation through Spring Boot Valid with Hibernate Validator, OWASP Java HTML Sanitizer for XSS and CSRF tokens enforced via Spring Security on all state-changing requests	O.INTEG, O.CONF

B2. Technology Stack [7 marks]

Layer	Technology	Security Justification
Frontend	React.js	The virtual DOM design was chosen over vanilla JavaScript because it structurally inhibits direct DOM manipulation, which leads to XSS. A stringent Content Security Policy (CSP) is implemented to prevent unwanted script execution and React automatically escapes dynamic material.
Backend	Spring Boot	Role-Based Access Control (RBAC) via PreAuthorize has built-in, sophisticated security features. Ensures that the least privileged concept is applied to all financial operations by limiting access to certain API endpoints to only authorized and authenticated users.
Authentication	Auth0	Delegate identity management to an enterprise-grade provider, guaranteeing robust accountability and high availability of the login service with obligatory MFA and centralized authentication tracking.
Database	PostgreSQL	Safeguards the safety and confidentiality of customer financial information when they are at rest by supporting native encryption tool integration and granular row-level protection.
Infrastructure	AWS	Strong network segmentation is made possible using Virtual Private Clouds (VPCs) and security groups, which reduce vulnerability to outside threats and provide high availability across several availability zones.
Secret Management	HashiCorp Vault	Protects confidentiality by ensuring API keys, certificates, and database credentials are not hardcoded in the application source code but instead retrieved securely and rotated dynamically.
Monitoring	ELK Stack	Ensures accountability by gathering, analyzing, and safely storing audit records in a consolidated, highly searchable database that facilitates forensic investigation and quick incident response.
CI/CD	GitHub Actions + Snyk	Protects system integrity by automatically scanning known vulnerabilities (CVEs) in third-party libraries and source code before any updates are deployed to production environments.
WAF	AWS WAF	Prevents harmful HTTP/HTTPS traffic from getting to the application layer. Protects availability from DDoS assaults by rate-limiting abusive requests and utilizing managed rule groups to block typical online vulnerabilities like SQL injection and cross-site scripting.

B3. Security Testing Plans [7 marks]

Tool / Method	Explanations	Scope	Frequency	Pass / Fail Criteria
SAST (SonarQube)	Crucial for identifying insecure coding practices early in the development lifecycle before the code reaches production.	Source code	Every commit	Zero critical findings and high findings require documented remediation plans before merge.
DAST (OWASP ZAP)	Essential for discovering runtime vulnerabilities by simulating real-world attacks against the live application.	Web application	Weekly automated scan	No unresolved Critical issues
Dependency Scanning (Snyk)	Ensure no third-party libraries with publicly known, exploitable vulnerabilities are used in the banking application.	All third-party libraries and open-source dependencies	Daily	No critical CVEs
Penetration Testing	Provides a realistic assessment of the application's defenses by employing human testers to chain together complex business logic flaws that automated tools often miss.	Entire application including authentication, transaction flows and admin functions	Quarterly	No high-risk vulnerabilities
Security Regression Testing	Ensure that new feature updates or routine bug fixes do not accidentally reintroduce previously patched security vulnerabilities, maintaining a consistent security posture.	Authentication module, transaction processing module, session management	Before every production release or end of each sprint	100% pass rate
Threat Modelling (STRIDE)	Proactively identify potential attack vectors across the system architecture during design and major feature updates, before implementation begins.	System architecture, data flows, API boundaries, authentication flows	At design phase and before any major feature update	All identified high and critical threats must be mitigated or formally accepted with written justification.

B4. Rationale [6 marks]

O.CONF: TOE ensures that protects customer information by employing TLS 1.3 for all data in transit and AES-256 encryption for data stored and saved within the PostgreSQL database. This cryptographic baseline is strengthened by Auth0 MFA and Spring Boot's RBAC which collectively guarantee that only strongly authenticated and authorized users can decrypt and view sensitive account data.

O.INTEG: Data integrity is protected using HMAC-SHA256 payload signing, which ensures that transaction requests are not tampered with during transmission. Furthermore, using AWS S3 Object Lock protects the centralized audit logs from unauthorized modification, while React's inherent escape features prevent malicious code injections from affecting the presentation of financial data.

O.AVAIL: The system ensures dependable access by spreading the infrastructure across AWS Multi-AZ (Availability Zones), which includes automated failover capabilities. This architectural redundancy, when combined with frequent automated database backups, allows quick disaster recovery and reduces downtime during hardware failures or cyber events.

O.AUTH: Strong authentication is enforced by using Auth0 as a centralized identity provider, which requires TOTP-based multi-factor authentication for all portal users. The system also actively protects against brute-force assaults by temporarily freezing accounts after five consecutive failed login attempts, ensuring that unique user identities are thoroughly confirmed before giving access.

O.AUDIT: The ELK Stack integration, which automatically captures, centralizes, and timestamps logs for all security-related events, firmly establishes accountability. Storing these logs in an immutable AWS S3 bucket ensures that they are preserved and tamper-proof for continuous monitoring, incident investigation, and regulatory compliance.

O.PRIV: The platform adheres to privacy-by-design principles by adopting stringent Role-Based Access Control (RBAC), which ensures that customer personal information is only accessible to banking staff with a strict need-to-know basis. Securing this data using strong AES-256 encryption assures compliance with the Personal Data Protection Act (PDPA) of 2010.

O.NONREP: To prevent users from falsely rejecting allowed operations, the system generates cryptographically signed transaction records with precise UTC timestamps and unique user identifiers for each financial transfer. These verifiable receipts are safely maintained in the database, giving irrefutable evidence for dispute resolution and auditing.

O.SESSMGMT: Secure session management is enforced using Auth0-issued JWT tokens signed with RS256. Each token is unique to the session and expires automatically after 15 minutes of inactivity. When a user logs out, the system immediately uses Auth0's /v2/logout endpoint to invalidate any active tokens on the server, prohibiting the reuse of stolen or abandoned session credentials. Spring Security also requires CSRF token validation for all state-changing requests to avoid session hijacking via cross-site attacks.

References

Amazon Web Services. (2024). AWS security best practices. <https://docs.aws.amazon.com/security/>

Bank Negara Malaysia. (2020). Risk Management in Technology (RMiT). <https://www.bnm.gov.my/rmit>

Common Criteria Recognition Arrangement. (2022). Common Criteria for information technology security evaluation (Version 3.1, Revision 6).

International Organization for Standardization. (2022). Information security, cybersecurity and privacy protection — Information security management systems — Requirements (ISO/IEC 27001:2022).

Laws of Malaysia. (2010). Personal Data Protection Act 2010 (Act 709). Commissioner of Law Revision, Malaysia.

Meta Platforms, Inc. (2024). React: The library for web and native user interfaces. <https://react.dev>

Okta, Inc. (2024). Auth0 documentation. <https://auth0.com/docs>

OWASP Foundation. (2025). OWASP Top 10 web application security risks. <https://owasp.org/Top10/>

OWASP Foundation. (2021). OWASP Application Security Verification Standard (ASVS) (Version 4.0.3). <https://owasp.org/www-project-application-security-verification-standard/>

PCI Security Standards Council. (2022). Payment Card Industry Data Security Standard: Requirements and testing procedures (Version 4.0). <https://www.pcisecuritystandards.org/standards/pci-dss/>

VMware, Inc. (2024). Spring Security reference. <https://docs.spring.io/spring-security/reference/>